

The
SozoRock.
Foundation

Health Systems Assurance

Volume 1

From compliance to evidence-based digital assurance

Dr. Oluwabiya Adeyemo

August 2026 ●

Health Systems Assurance

Volume 1 | From compliance to evidence-based digital assurance

Author	Dr. Oluwabiyi Adeyemo
Publisher	The SozoRock Foundation Inc.
Edition	First edition
Published	August 2026 Albany, New York, USA
Evidence cutoff	August 12, 2026
ISBN	979-8-9936477-3-9
Contact	health.sozorockfoundation.org contact@sozorockfoundation.org

Suggested citation

Adeyemo, Oluwabiyi. 2026. Health Systems Assurance, Volume 1: From compliance to evidence-based digital assurance. Albany, New York: The SozoRock Foundation Inc.

Copyright and permissions

© 2026 The SozoRock Foundation Inc. All rights reserved. Third-party standards, trademarks, institutional names, and copyrighted source materials remain the property of their respective owners. References to external organizations and standards are for identification and analysis and do not imply endorsement. Proprietary standard text and other protected source material are not reproduced. Permissions and publication inquiries: contact@sozorockfoundation.org.

About this report

This publication presents independent public-interest research and policy analysis centered on U.S. health-system evidence. International standards and research provide comparative context. It does not provide legal or clinical advice, establish a certification or attestation scheme, or audit any organization. The Health Systems Assurance framework connects obligations and risk objectives to operating evidence, monitoring, exceptions, remediation, and accountable decisions. Its assessment properties and implementation effects remain subjects for empirical study.

Published by The SozoRock Foundation Inc. in Albany, New York, USA. SozoRock® is a registered trademark of SozoRock Tech Inc., used under license by The SozoRock Foundation.

Contents

At a glance	1
Executive synthesis	3
1. Digital dependence has changed the assurance problem	6
2. The problem is not a lack of standards	10
3. Assurance objectives may be common; implementation conditions are not	15
4. AI authorization is a starting point, not an assurance conclusion	21
5. From compliance to evidence: the decision must be supportable	27
Research agenda: what should be tested next	33
Methods	34
Limitations	35
Notes and sources	36
Acknowledgments and disclosures	38

At a glance

Digital adoption is widespread. Operating assurance is the harder problem.

U.S. hospitals have moved from basic digitization toward deep dependence on exchange networks, vendors, cloud services, identity systems, and increasingly AI-enabled tools. Laws, standards, frameworks, certifications, and attestations remain essential, but each answers a different assurance question. Current operating evidence is still needed for the material workflow being trusted.

76% of hospitals engaged in all four measured exchange domains in 2025. [1]	43% of hospitals reported current TEFCA participation in weighted 2025 estimates. [2]	99.5% certified EHR adoption among both rural and urban hospitals in 2024. [37]	6 of 19 health-system AI governance frameworks in a 2026 review were derived from primary studies. [27]
---	---	---	---

Five findings

- Digital dependence makes assurance an operating question as well as a compliance question.
- The assurance gap appears when useful mechanisms answer different questions without a clear line to local operating evidence.
- Documentation and operating evidence are different evidentiary states. A policy, design, certification, or vendor report may support a claim without proving that a local material capability works as intended today.
- Implementation conditions vary. Geography, workforce, financial capacity, system affiliation, contracting leverage, and recovery alternatives shape how assurance can be implemented; accountability still applies.
- AI and third-party dependencies extend assurance across a lifecycle and across organizational boundaries, while organization-specific operating effectiveness remains largely outside public datasets.

Sources: [1] ASTP/ONC Health IT Quick Stat #66; [2] ASTP/ONC Health IT Quick Stat #64; [37] ASTP/ONC Health IT Quick Stat #52; [27] Alami et al., 2026. These measures describe adoption and participation; they do not establish assurance maturity.

What these findings mean for decisionmakers

The immediate task is to make evidence responsibilities explicit and concentrate deeper verification on digital capabilities whose failure would materially affect care, privacy, access, continuity, or public trust.

1	Prioritize material capabilities Concentrate deeper evidence and verification on systems whose failure could materially affect care, privacy, access, continuity, or public trust.
2	Move from documentation to operating evidence Connect requirements and risk objectives to accountable owners, current evidence, monitoring, exceptions, remediation, and decisions.
3	Build proportionately Use shared services, technical assistance, and common evidence infrastructure so smaller organizations are not asked to reproduce enterprise-scale assurance machinery.

A practical leadership test

For any material digital capability, leaders should be able to answer five questions without assembling a new project team:

- What must continue to work for the care or operational pathway to function?
- Which critical dependencies sit inside and outside the organization?
- What current evidence shows that the capability and its safeguards are operating as intended?
- What exception or failure conditions trigger remediation, fallback, escalation, or suspension?
- Who owns the residual risk and the decision to continue, change, or stop use?

EVIDENCE NOTE

Public data can describe adoption, participation, organizational context, and published disruptions. Organization-specific assurance requires direct operating evidence.

Executive synthesis

Digital dependence has changed the oversight question

Health care has become inseparable from digital infrastructure. A patient encounter may depend on identity services, electronic health records, laboratory and imaging systems, pharmacy connections, health information networks, cloud platforms, vendor-hosted applications, communications services, and increasingly AI-enabled tools. That creates a longer chain of dependencies whose failure can change how care is delivered.

The scale of that shift is visible in hospital exchange. In 2014, 23 percent of U.S. non-federal acute-care hospitals reported engaging in all four measured domains of electronic health information exchange - sending, receiving, finding, and integrating information. By 2025, the share was 76 percent. TEFCA adds another layer of shared infrastructure: 43 percent of hospitals in a cited 2025 survey reported current participation and another 37 percent planned to participate. By June 2026, HHS reported one billion health records exchanged through the network. The direction is clear. Health organizations increasingly operate inside networks of networks that include systems they do not control directly. [1-3,12]

Interoperability can improve continuity, access to information, coordination, and patient access. That value comes with a broader oversight requirement. A system can be available while a workflow still fails because identity, interface, vendor, network, configuration, or recovery dependencies are not functioning as expected. The object of oversight is the material capability as experienced in operation, including the applications and policies on which it depends.

KEY POINT

Modern health care already has standards and controls. The assurance challenge is connecting them to operating evidence, measurement, exceptions, remediation, and accountable decisions across an interconnected digital environment.

Sources: [1-3] ASTP/ONC interoperability and TEFCA sources; [12] TEFCA program description. Exchange measures describe connectivity and participation, not assurance quality.

The rules exist. The unresolved issue is operating evidence.

Health care already operates under a substantial set of legal duties, risk frameworks, control catalogs, assessment procedures, management-system standards, certifications, attestations, exchange rules, and AI-governance guidance. These mechanisms are useful precisely because they do different jobs. HIPAA establishes legal obligations around electronic protected health information. NIST CSF organizes cybersecurity outcomes. NIST SP 800-53A provides procedures for assessing controls. HHS publishes healthcare-specific cybersecurity performance goals. SOC 2 reports provide scoped third-party assurance. ISO standards address information security, quality management, and AI management systems. TECCA governs nationwide exchange. Their roles should remain distinct because each establishes a different kind of evidence about a local care workflow. [4-16]

The practical gap appears when leaders move from asking whether a requirement exists to asking whether a material capability can be trusted today. A policy can demonstrate stated intent. A design document can show how a safeguard is supposed to work. An attestation or certification can provide useful scoped evidence. But current operating trust requires another layer: evidence that the relevant practice is operating, that performance is being observed, that exceptions are visible, that remediation occurs, and that someone is accountable for the residual decision.

EVIDENCE TEST

Documentation can establish intent or design. Operating assurance asks what the evidence supports in practice, within what scope, and what remains unproven.

Capacity changes implementation, not the objective

Current public evidence also argues against a simplistic digital-divide narrative. Certified EHR adoption reached 99.5 percent among both rural and urban non-federal acute-care hospitals in 2024. Yet participation in newer shared infrastructure was less even: in the cited 2025 TECCA survey, 51 percent of multi-hospital system members reported current participation compared with 25 percent of independent hospitals, while 30 percent of Critical Access Hospitals reported current participation compared with 48 percent of non-CAHs. These measures answer different questions, but together they show why basic adoption should not be treated as a proxy for implementation capacity. [2,37]

HSA implication: proportional implementation can change sequencing, tooling, technical assistance, and use of shared services without making accountability for material risk optional.

Disruption and AI make the evidence problem operational

Published disruption studies make the stakes visible. Research on a ransomware attack affecting four hospitals found significant increases in patient census, ambulance arrivals, waiting time, and admitted-patient length of stay at adjacent unaffected emergency departments. A separate Medicare-based analysis found sharp first-week reductions in inpatient, outpatient, and emergency volumes at attacked hospitals, with rural facilities facing substantially longer travel time and distance to the nearest nonattacked hospital. The 2024 CrowdStrike outage showed that a non-malicious software failure could also disrupt patient-facing and operational hospital services at scale. Together, these studies support treating digital resilience as a care-delivery issue while stopping short of a universal causal claim that every digital failure produces patient harm. [24-26]

AI adds another layer because implementation evidence has not kept pace with the growth of governance guidance. A cited 2026 systematic review identified 19 health-system AI governance frameworks, only six of which were derived from primary studies. A separate 2026 scoping review identified 77 frameworks and found that only 10 contained all four components examined by the authors: principles, assessment methods, lifecycle stages, and oversight mechanisms. The practical gap is between broad agreement about the need for governance and thinner evidence about which organizational arrangements work reliably in routine care. [27-28]

What Volume 1 proposes

Volume 1 proposes an evidence architecture that connects eight questions around a material digital capability: What objective are we trying to assure? What authority, obligation, or risk gives that objective weight? What evidence supports the claim? How is the evidence verified? How is operation monitored? What counts as an exception? How is the exception remediated or accepted? Who makes the accountable decision?

The report also introduces an HSA Evidence Ladder - Unknown, Stated, Designed, Operating, Measured, and Assured - to distinguish increasingly strong evidentiary states. The ladder is presented as a research construct, not a certification scheme or regulatory standard; its reliability and validity remain to be tested.

ACTION FOR LEADERS

Identify the 10 to 15 digital capabilities whose failure would most disrupt care, privacy, access, or continuity; assign an accountable owner and evidence owner for each; create a controlled assurance register; test at least one complete recovery pathway; and inventory AI-enabled use cases and critical third parties.

Public evidence cannot determine whether a specific organization's controls are effective in operation or whether the HSA architecture is reliable, valid, cost-effective, or outcome-improving. Those questions require direct operating evidence and empirical research.

1

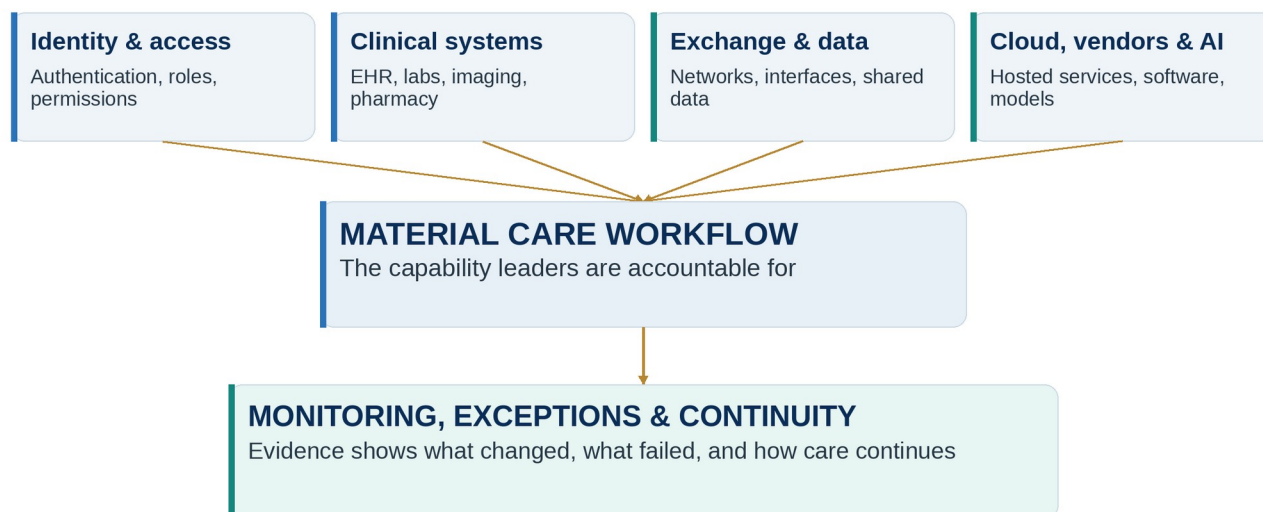
Digital dependence has changed the assurance problem

As care depends on more interconnected systems and organizations, the relevant question shifts from whether a single application is available to whether the full capability can be trusted when conditions change.

A modern patient encounter can depend on services that sit far beyond the walls of a hospital or clinic. Identity and authentication systems determine who can enter a workflow. Electronic health records organize clinical information. Laboratory and imaging platforms provide diagnostic inputs. Pharmacy connections support medication workflows. Health information networks move records across organizations. Cloud platforms host critical services. Communications and scheduling tools shape access. Vendors operate applications and infrastructure that a health organization may not directly control.

EXHIBIT 1.1

A material care workflow can depend on systems outside direct organizational control



Source: The SozoRock Foundation analysis. The diagram illustrates dependency categories rather than a universal technical architecture.

The shift is that these services increasingly form an interdependent chain. A failure in one layer can affect another, and the organization delivering care may not control every point in that chain. Assurance therefore becomes a question about the capability as experienced in operation: whether dependencies are known, whether failure is visible, whether evidence is current, whether recovery and workaround paths have been tested, and whether unresolved risk reaches an accountable decisionmaker.

Electronic exchange has become routine infrastructure

Interoperability is the clearest measure of how quickly the operating environment has changed. The share of U.S. non-federal acute-care hospitals reporting all four measured electronic exchange domains rose from 23 percent in 2014 to 76 percent in 2025. That is a 53-percentage-point increase in the share of hospitals participating across the full measured exchange set. [1]

EXHIBIT 1.2

Electronic exchange moved from minority activity to routine infrastructure



Source: [1] ASTP/ONC, Electronic Health Information Exchange by Hospitals, Health IT Quick Stat #66. Weighted survey estimates. These measures describe exchange activity, not assurance quality or cybersecurity maturity.

TEFCA extends the same structural trend through a nationwide network-of-networks model. In the cited 2025 survey, 43 percent of hospitals reported current participation and another 37 percent planned to participate. By June 2026, HHS reported one billion health records exchanged through the network. [2,3,12]

INTERPRETATION

More care now relies on shared digital infrastructure that crosses organizational boundaries. Connectivity has scaled faster than public evidence about the operating effectiveness of any one organization's controls.

Networks of networks change what leaders need to know

When a care pathway depends on interconnected organizations and services, assurance cannot stop at the boundary of the asset inventory. Leaders need to understand the capability end to end: which services are material, which dependencies are inherited, what local configuration can change, how failures surface, and what continuity options exist.

From an application	to a material capability	What must work together for the care process to function?
From owned systems	to shared dependencies	Which networks, vendors, cloud services, and interfaces sit outside direct control?
From periodic proof	to current operating evidence	How do leaders know that controls and workarounds still operate when conditions change?
From incident response	to continuity of care	What happens to the care pathway when a critical service becomes unavailable?

The assurance unit is the capability, not the document

This framing matters because a capability can be supported by multiple forms of evidence at once. A vendor report may establish something about a hosted service. An internal access review may establish something about local permissions. A network agreement may establish something about exchange obligations. A downtime test may establish something about continuity. Each item can be valid evidence without being sufficient evidence for the whole capability.

The practical discipline is therefore to connect evidence to the specific claim it supports, preserve the boundary of that claim, and identify the remaining gaps. That is different from collecting documentation until a file appears complete.

DECISION QUESTION

If a material digital capability changed tonight - because of a vendor release, network outage, identity failure, configuration error, cyber incident, or AI-model change - what evidence would tell leadership whether the capability should keep operating tomorrow morning?

Digital failure can become an operational care problem

The strongest reason to treat assurance as an operating discipline is that digital failure can propagate into access, throughput, scheduling, diagnostics, referral, and regional capacity. Current evidence supports that operational conclusion without establishing a universal causal link from every cyber or software event to patient harm.

Digital disruption can become an operational care problem

RANSOMWARE SPILLOVER 2021 event affecting four hospitals	OBSERVED SIGNAL Nearby emergency departments reported higher census, ambulance arrivals, wait time, and admitted-patient length of stay.	WHAT THE EVIDENCE SUPPORTS [24] Regional operations can be affected beyond the attacked facility.
RURAL & URBAN RANSOMWARE Medicare event study	OBSERVED SIGNAL Attacked hospitals saw sharp first-week volume reductions; rural patients faced much greater distance to alternatives.	WHAT THE EVIDENCE SUPPORTS [25] Recovery burden depends partly on local system structure.
CROWDSTRIKE OUTAGE 2024 software-update failure	OBSERVED SIGNAL Patient-facing and operational network services were disrupted across hundreds of U.S. hospitals.	WHAT THE EVIDENCE SUPPORTS [26] Resilience must address vendor and software failure as well as attacks.

Sources: [24] Dameff et al., 2023; [25] Neprash et al., 2024; [26] Tully et al., 2025. Observational evidence should not be generalized into a universal claim that every digital failure causes patient harm.

Resilience planning should account for malicious attacks and ordinary technology failures and should be tested against the care pathways that depend on digital services. Relevant evidence includes a recovery plan and tested detection, fallback, restoration, communication, and clinical workarounds under realistic conditions.

Materiality is the practical threshold for deeper assurance

Not every application needs the same level of evidence. A workable assurance discipline begins by identifying which digital capabilities are material enough that failure could meaningfully affect care, privacy, access, continuity, financial operations, or public trust. Materiality allows organizations to concentrate scarce verification effort where the consequence of failure is greatest.

A five-question materiality test

- Consequence: Could failure materially affect care delivery, privacy, access, continuity, or public trust?
- Dependency: Which systems, networks, vendors, identities, interfaces, data sources, or AI components must function together?
- Evidence: What current evidence shows that the capability and its key safeguards are operating as intended?
- Exception: What conditions trigger fallback, investigation, remediation, escalation, reauthorization, or stop-use?
- Decision: Who has the authority and accountability to accept residual risk or require change?

2

The problem is not a lack of standards

Health care already operates with a substantial set of assurance mechanisms. Legal rules establish duties. Cybersecurity frameworks organize risk. Control guidance and assessment procedures help define and test practices. Attestations provide scoped external evidence. Exchange frameworks establish network rules. AI governance standards organize another class of lifecycle risk. These mechanisms are useful and necessary, but they answer different questions.

Treating all of them as one category called compliance creates two errors. First, it overstates what a single mechanism can prove. Second, it makes it harder to see where organization-specific operating evidence is still required. A hospital can satisfy an obligation, use a recognized framework, obtain a vendor report, and participate in a trusted network while still needing local evidence about configuration, access, workflow reliability, monitoring, exceptions, and continuity.

LAW sets duties	FRAMEWORK organizes risk	ASSESSMENT tests controls
ATTESTATION adds scoped evidence	NETWORK sets exchange rules	AI GOVERNANCE structures lifecycle risk

The practical question

For a material capability, which mechanism establishes the relevant duty or risk objective - and what additional evidence is needed before leadership can make a credible operating decision?

KEY FINDING

Existing mechanisms are complementary. Assurance improves when organizations preserve their different roles and connect them to the specific operating evidence needed for the capability being trusted.

Source: The SozoRock Foundation analysis of official source descriptions [4-16]. Proprietary ISO clauses and AICPA criteria are not reproduced.

Different mechanisms answer different assurance questions

The useful distinction is functional. A law can make something mandatory without prescribing every implementation detail. A risk framework can organize outcomes without establishing legal compliance. Assessment guidance can test whether controls operate as intended without becoming a healthcare-specific safety standard. An attestation can add independent evidence within a defined service scope without proving the customer organization configured or uses that service correctly.

Existing mechanisms answer different assurance questions

MECHANISM	PRIMARY ROLE	WHAT IT CAN ESTABLISH
HIPAA Security Rule	Legal duties	Required safeguards and compliance evidence
NIST CSF / HHS CPGs	Risk and control priorities	Cybersecurity outcomes and prioritized practices
NIST SP 800-53A	Assessment procedures	Evidence from examine, interview, and test
SOC 2 / ISO standards	Scoped assurance / management systems	Defined service or management-system evidence
TEFCA	Exchange governance	Participation and network-level requirements
AI RMF / ISO 42001	AI risk and governance	Lifecycle risk-management and governance practices

Each mechanism is useful within scope; local operating evidence is still needed for end-to-end trust.

Sources: [4-16]. Matrix shows principal roles only and is not an exhaustive legal or standards crosswalk.

This is also why certification and management-system evidence should be read within scope. ISO 27799:2025 focuses on information-security controls in health settings; ISO 7101:2023 addresses management systems for quality in healthcare organizations; ISO/IEC 42001:2023 addresses AI management systems. These mechanisms can reinforce one another, but their coexistence does not create a single end-to-end assurance judgment. [10,11,16]

Documentation and operating evidence are different states

An organization can have a well-written policy and still be unable to show that the relevant practice operated when it mattered. Policies and procedures describe intent. Designs and configurations show how a control or workflow is supposed to work. Logs, completed reviews, test results, tickets, monitoring data, exercises, incident records, and remediation evidence can show what happened in operation. Each item is useful; none should be asked to prove more than its scope allows.

Evidence has to connect the requirement to an accountable decision



Source: NIST SP 800-53A and NIST SP 800-137 [7,8], with The SozoRock Foundation analysis.

NIST SP 800-53A is useful here because it treats assessment as determining whether controls are implemented correctly, operating as intended, and producing the desired outcome. NIST SP 800-137 adds an ongoing-awareness logic that complements periodic assessment. HSA uses that general evidence principle without adopting either publication wholesale. [7,8]

Evidence should be scoped to the claim being made

The main credibility risk is an oversized conclusion. Evidence becomes misleading when it is used to support a broader claim than it was designed to answer. The discipline is simple: state what the evidence supports, state what it does not establish, and identify the remaining local proof burden.

Evidence item	What it can support	What it cannot prove by itself
A SOC 2 report	can support a scoped claim about controls at the service organization.	does not by itself prove correct local configuration, clinical workflow performance, or continuity at the customer organization. [9]
TEFCA participation	can support a claim about participation in a nationwide exchange framework and its network rules.	does not by itself establish assurance over every internal system, interface, identity process, or workflow. [12]

Evidence item	What it can support	What it cannot prove by itself
An AI governance framework or management-system standard	can support governance, risk-management, and lifecycle-process claims within scope.	does not automatically establish local clinical validity, effectiveness, or performance after change. [15,16]
A policy or procedure	can establish stated intent, assigned responsibilities, and expected process.	does not prove that the practice occurred, was complete, or remained effective when conditions changed. [7,8]

Evidence has a shelf life

The HIPAA Security Rule provides a straightforward example. As of the August 12, 2026 evidence cutoff used for Volume 1, HHS stated that the current Security Rule remained in effect while the 2024 notice of proposed rulemaking to strengthen cybersecurity remained a proposal. A proposed requirement cannot be written as though it were already enforceable. The same discipline applies to standards revisions, framework updates, contract changes, vendor releases, and AI-model changes: the evidence record must identify which version governed the decision. [5]

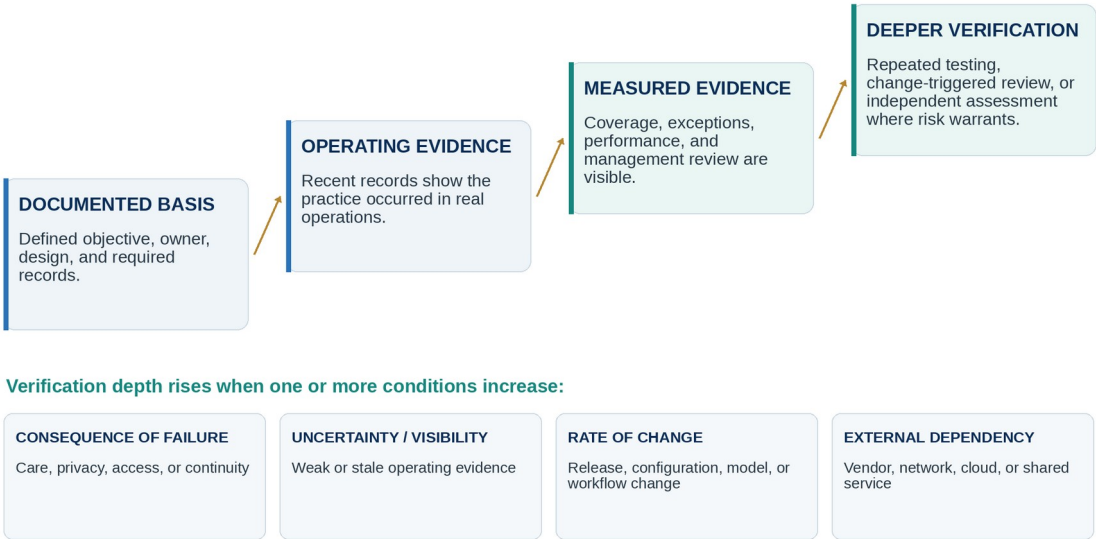
EVIDENCE PRINCIPLE

A credible assurance statement is scoped to a requirement, a system or workflow, a period of time, a source of evidence, and the conditions under which the conclusion may need to be revisited.

Evidence depth should scale with consequence, uncertainty, dependency, and rate of change. A stable, low-consequence administrative capability may warrant a lighter review pattern than a service that controls identity, clinical decision support, critical results, health-information exchange, or multi-site continuity.

EXHIBIT 2.3

Verification depth should rise with consequence, uncertainty, and change



Source: The SozoRock Foundation, informed by assessment and monitoring principles [7,8]. Verification depth should remain proportionate to risk and applicable requirements.

Cadence should follow the same logic. Some telemetry can be reviewed continuously or near real time. Access recertification, vulnerability review, and vendor evidence may operate on recurring cycles. Major changes, AI releases, incidents, failed tests, or threshold breaches may justify event-triggered reassessment. In HSA, monitoring frequency is set by the assurance objective, consequence, rate of change, and evidence availability.

Connect existing mechanisms to operating evidence

Health Systems Assurance can add value by connecting the relevant requirement or risk objective to the evidence a health organization needs for a specific material capability, while keeping ownership, exceptions, remediation, and decisions visible. It complements HIPAA, NIST, ISO, SOC 2, TECCA, certification requirements, and AI governance frameworks. For leadership, the test is straightforward: can the organization show the governing objective, current evidence, unresolved exceptions, and the accountable decision path?

- | | |
|---|---|
| 1 | Preserve authority - Use the law, standard, framework, contract, or clinical requirement that governs the objective. |
| 2 | Scope the claim - State what the evidence supports and what still needs local proof. |
| 3 | Assign evidence ownership - Name who produces, reviews, refreshes, and acts on the evidence. |
| 4 | Close the loop - Keep exceptions, remediation, retesting, and residual-risk decisions visible. |

3

Assurance objectives may be common; implementation conditions are not

A material digital capability should not become less accountable because an organization is small, rural, independent, safety-net, or resource constrained. But the way an organization produces evidence, monitors a dependency, tests recovery, or obtains specialist review may need to differ substantially. The implementation problem is therefore one of proportional delivery, not reduced responsibility.

Organizations differ in scale, system affiliation, workforce, financial flexibility, geography, connectivity, contracting leverage, vendor concentration, and access to recovery alternatives. Those conditions can affect which capabilities are practical to build internally, which are better shared, and how quickly an assurance program can mature. They do not, by themselves, establish whether controls are strong or weak.

Scale & affiliation

Shared staff, centralized implementation and procurement may change what can be supported internally.

Workforce & expertise

Specialist availability and role coverage shape the burden of evidence collection, testing and remediation.

Place & connectivity

Geography and connectivity can affect access to support, service alternatives and recovery options.

Dependency & recovery

Vendor concentration, network reliance and fallback choices shape the consequence of external failure.

KEY FINDING

Capacity affects how assurance is delivered. Material risks still require traceable evidence and accountable decisions.

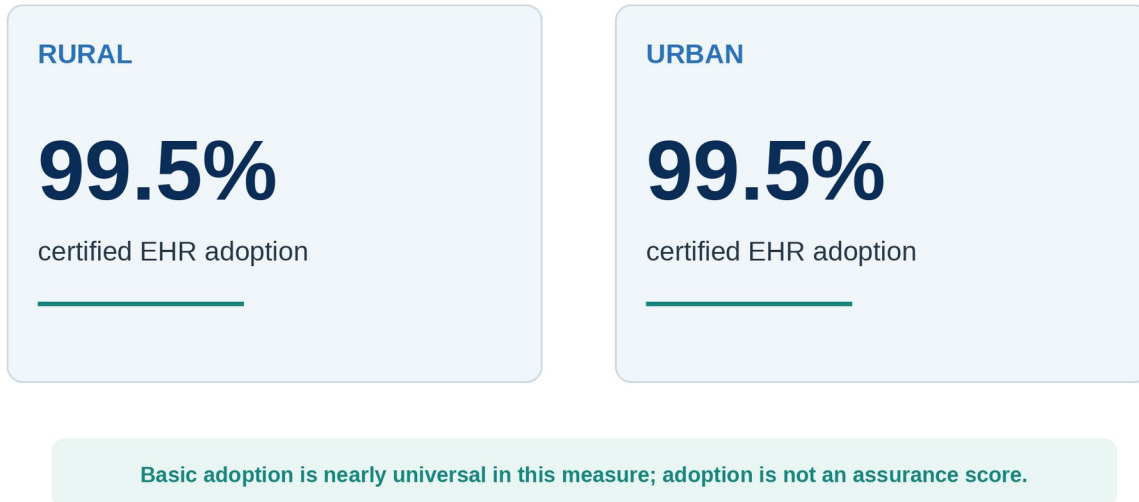
The available public evidence supports a careful version of this argument. It shows that basic certified EHR adoption is already nearly universal while participation in newer shared infrastructure differs across organizational contexts. The evidence can describe the pattern. It cannot identify its cause or score an organization's assurance maturity. [2,37]

Basic EHR adoption is no longer a useful proxy for the rural digital divide

In cited 2024 data, 99.5 percent of both rural and urban U.S. non-federal acute-care hospitals possessed certified EHR technology. Adoption also exceeded 99 percent across hospital size groups. The finding matters because it narrows the question leaders should ask. Basic digitization can be widespread even when organizations face very different conditions for governing newer networks, vendors, identity systems, cloud services, AI-enabled tools, and recovery pathways. [37]

EXHIBIT 3.1

Basic EHR adoption no longer distinguishes rural from urban hospitals in this measure



Source: ASTP/ONC, Percent of Hospitals, By Type, that Possess Certified Health IT, Health IT Quick Stat #52 [37]. Selected 2024 hospital categories. Adoption does not measure assurance maturity.

INTERPRETATION

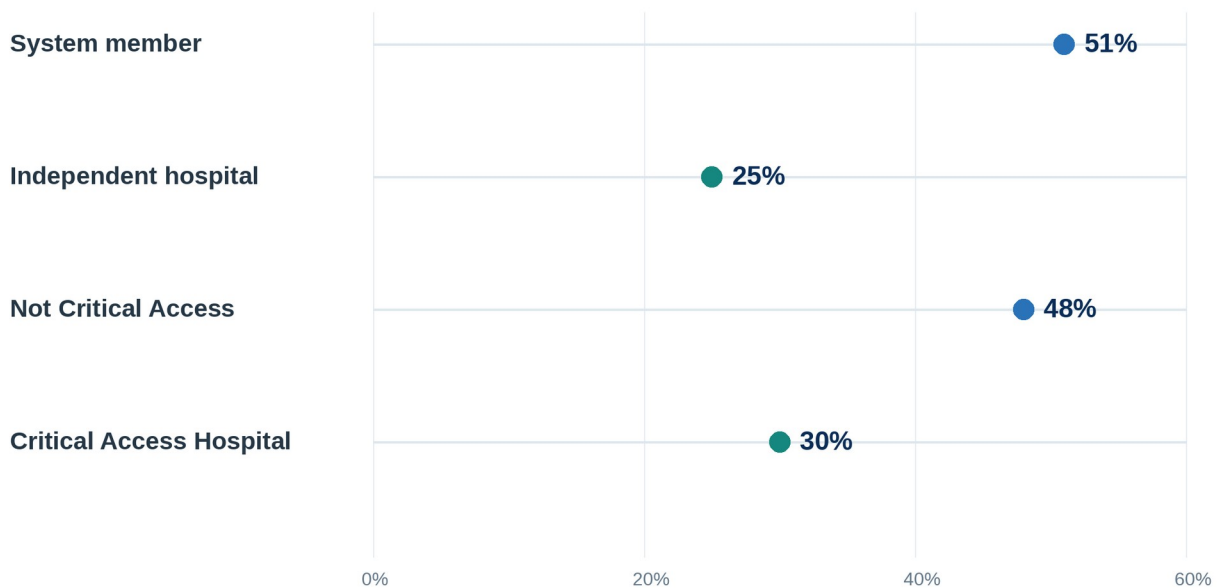
The useful question has shifted from whether basic digital infrastructure exists to which capabilities and institutional conditions shape an organization's ability to govern newer dependencies and produce reliable operating evidence.

This distinction prevents a familiar analytical error: using rurality, size, or financial condition as a stand-in for digital competence. A contextual variable can help explain implementation burden without proving control effectiveness. The report therefore treats place and capacity as conditions to be studied, not as a ranking system.

Participation in newer shared infrastructure differs by organizational context

The 2025 hospital survey on the Trusted Exchange Framework and Common Agreement (TEFCA) shows a different pattern from basic EHR adoption. Fifty-one percent of multi-hospital system members reported current participation, compared with 25 percent of independent hospitals. Current participation was 48 percent among non-Critical Access Hospitals and 30 percent among Critical Access Hospitals. Hospitals already participating in both national and state, regional, or local network types also reported much higher TEFCA participation than hospitals participating in neither. [2]

Current TEFCA participation differs by organizational context



Source: ASTP/ONC, Non-Federal Acute Care Hospitals' Awareness of and Plans to Participate in TEFCA, Health IT Quick Stat #64 [2]. Weighted 2025 AHA IT Supplement estimates; response rate 55 percent for non-federal acute-care hospitals.

SURVEY LIMITS

The differences justify inquiry, not causal attribution. Shared infrastructure, system affiliation, contracting leverage, implementation support, network relationships, geography, or other factors may contribute. The cross-sectional survey cannot determine which explanations matter most.

That boundary is important for policy. A lower participation rate in one category is not evidence that the category has weaker internal controls. It is evidence that implementation conditions differ enough to warrant closer analysis of what support, shared capacity, and sequencing may be required.

The assurance burden is shaped by capacity, geography, and recovery options

Public datasets can make implementation context more visible. CMS hospital cost reports can support analysis of facility characteristics, utilization, costs, and financial conditions. HRSA's Area Health Resources Files combine workforce, facilities, resource scarcity, population, economic, and environmental indicators. FCC broadband data can characterize provider-reported availability around communities and facilities. These sources can support stratification and place-based analysis; they cannot substitute for organization-specific assurance evidence. [20-22]

EXHIBIT 3.3

Capacity and place shape delivery options, not the assurance judgment



Sources: CMS HCRIS [20], HRSA Area Health Resources Files [21], and FCC National Broadband Map guidance [22]. Structural indicators describe context; they are not assurance scores.

This boundary matters because a composite score can become misleading very quickly. A hospital may have thin margins, limited local connectivity options, a small workforce, and long travel distances to alternative care while still maintaining disciplined controls through a system affiliation, managed service provider, regional collaboration, or strong local leadership. A large and well-resourced organization can also experience serious failures.

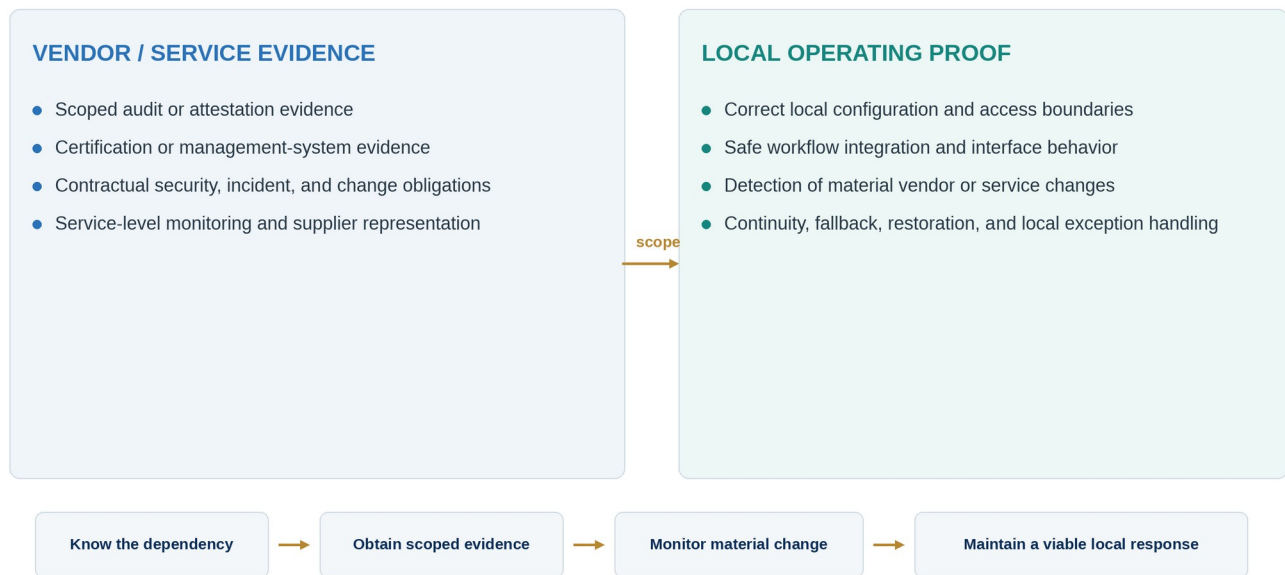
CONTEXT NOTE

Structural indicators describe implementation context; operating effectiveness requires direct evidence.

Outsourcing a function does not outsource the operational consequence of failure

Health organizations increasingly rely on systems and services they do not build or operate themselves: cloud platforms, electronic health record vendors, laboratory and imaging services, communications providers, networks, payment systems, security tools, AI services, and specialized applications. NIST supply-chain guidance emphasizes the reduced visibility and control that accompany acquired products and services. For health systems, that dependency also becomes a continuity, workflow, data-integrity, and change-management question when failure can alter care delivery. [19]

Vendor evidence cannot establish every local workflow claim



Sources: NIST SP 800-161 Rev. 1 [19]; SOC 2 scope logic [9]. Third-party reports, certifications, contracts and questionnaires can be useful evidence within defined scope.

Change visibility is a particularly important boundary. A vendor may change a model, hosting region, subprocessor, authentication architecture, software version, data-handling practice, or service dependency without the health organization changing its own internal policy. Material changes should therefore have a review path proportionate to their clinical, operational, privacy, security, and continuity consequences.

CONTINUITY QUESTION

Not every organization can maintain a fully redundant alternative for every vendor. Every material dependency should still have a conscious continuity decision: a workaround, manual procedure, alternate service, restoration expectation, exit path, or explicit risk acceptance.

Shared assurance capabilities can reduce duplicated burden without lowering the objective

The implementation response should not be to recreate enterprise bureaucracy inside every smaller organization. It should be to preserve the evidence and accountability functions that matter, then choose the least burdensome delivery model that can support them. Current NIST implementation resources explicitly recognize smaller organizations with modest or emerging cybersecurity programs, while HHS healthcare cybersecurity resources emphasize prioritized practices across organizations of different sizes. Those sources support proportional implementation; they do not remove applicable legal obligations. [4,32,40]

A practical shared-capability agenda

Actor	Practical role	Decision test
States / public programs	Support shared technical assistance, procurement templates, resilience exercises and targeted implementation capacity.	Can smaller organizations meet the same material objective without reproducing enterprise-scale machinery?
Health systems, HIEs & associations	Pool selected monitoring, vendor-evidence review, specialist assurance support and regional continuity exercises.	Does shared capability produce usable local evidence and a clear escalation path?
Vendors & networks	Provide scoped assurance evidence, customer-control expectations, material-change notice, incident obligations and continuity information.	Can the customer tell what changed, what the evidence covers, and what local action is required?
Funders & research institutions	Fund implementation pilots, evidence tooling, burden and cost studies, and evaluation across resource-diverse settings.	Does investment improve operating evidence and resilience rather than add reporting burden?

Some capabilities may be more efficiently provided through health systems, health information exchanges, associations, state programs, managed service providers, academic partnerships, or nonprofit technical-assistance models. Candidate shared functions include selected monitoring, vendor evidence review, vulnerability management, tabletop exercises, AI evaluation support, evidence tooling, and specialist assurance testing. The local organization still owns the decision about material risk. [32,40]

KEY POINT

Proportional implementation can change sequencing, tooling, staffing, and delivery model while preserving traceable evidence, visible exceptions, viable recovery decisions, and accountable leadership.

AI sharpens this implementation problem because authorization is only the beginning. Once an AI-enabled capability is in use, evidence has to persist through monitoring, human oversight, material change, incidents, reauthorization, and retirement. Assurance therefore becomes a lifecycle responsibility that continues after launch.

Resource level, geography, system affiliation, and vendor choice describe implementation context; they do not establish assurance quality.

4

AI authorization is a starting point, not an assurance conclusion

An AI-enabled capability can be reviewed carefully before go-live and still become a different assurance problem after it begins operating. Performance can vary across populations and workflows. Data can change. Users can adapt their behavior. A vendor can release a new model or version. Interfaces can be redesigned. Monitoring can fail. An incident can reveal that assumptions made at authorization no longer hold.

The useful governance question is whether an organization can show what an AI system is allowed to do, what evidence supported the decision to use it, who accepted the residual risk, how operation is monitored, what happens when evidence falls outside tolerance, and what changes require reauthorization or retirement.

KEY FINDING

AI assurance is a lifecycle responsibility because the evidence supporting trust can change after authorization.

Current frameworks support that lifecycle orientation without resolving every local assurance question. NIST AI RMF 1.0 organizes AI risk management through Govern, Map, Measure, and Manage and is being revised. ISO/IEC 42001:2023 establishes requirements for an AI management system. WHO guidance addresses ethics, accountability, safety, transparency, equity, and regulatory considerations. In the United States, HTI-1 and the Decision Support Interventions certification materials add transparency and intervention-risk-management requirements within their defined certified-health-IT scope. [13-18]

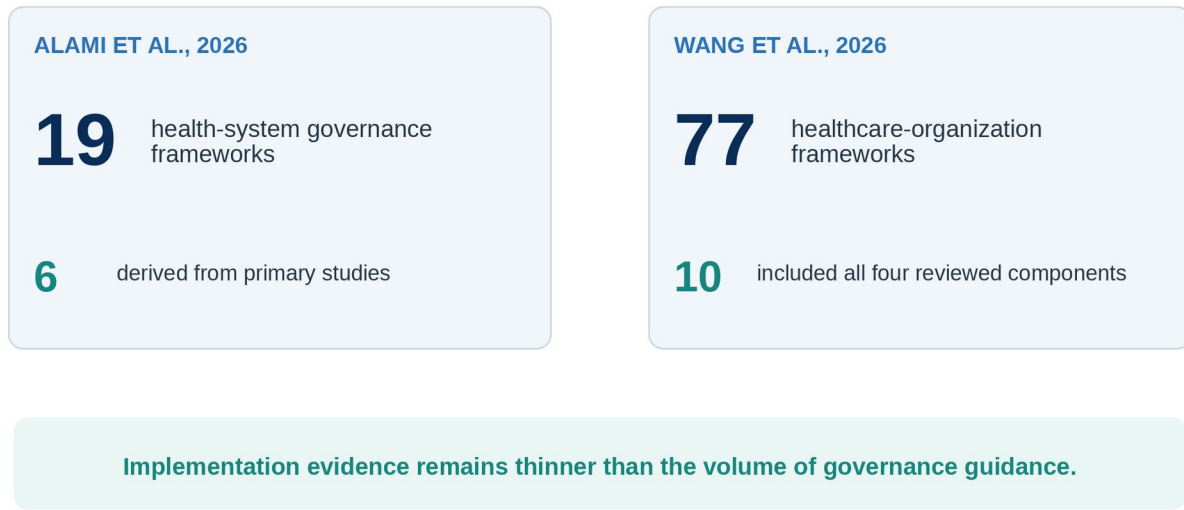
These mechanisms strengthen governance and transparency. Local clinical validity, operational performance, and enterprise-wide assurance for a specific AI use case require additional evidence.

The field has more governance frameworks than demonstrated implementation practice

Two 2026 evidence syntheses make the gap visible. Alami and colleagues identified 19 health-system AI governance frameworks and found that only six were derived from primary studies. Wang and colleagues identified 77 frameworks for healthcare organizations; only 10 included all four components assessed in their review - principles, assessment methods, lifecycle stages, and oversight mechanisms. [27,28]

EXHIBIT 4.1

Implementation evidence lags the growth of AI governance guidance



Sources: Alami et al. [27]; Wang et al. [28]; implementation synthesis [29]. These reviews support implementation research; they do not demonstrate that any governance framework, including HSA, improves clinical outcomes or organizational reliability.

A separate implementation synthesis reinforces the practical point: live implementation is shaped by infrastructure, access to knowledge, organizational culture, perceived complexity, and workflow fit. The evidence base on how institutions translate governance principles into reliable operating practice remains comparatively thin. [29]

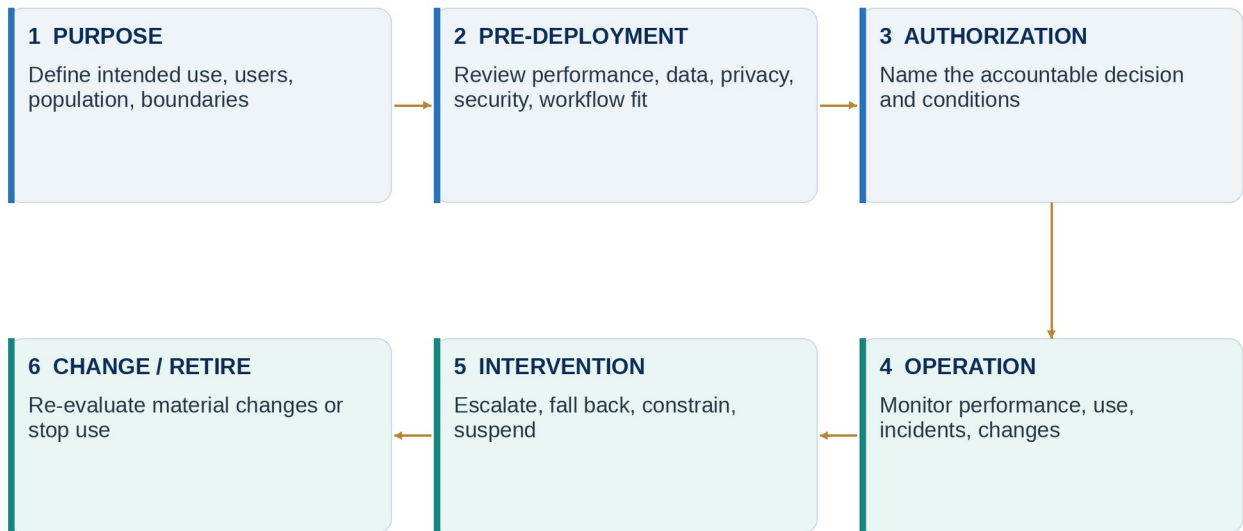
EVIDENCE NOTE

Governance, validation, monitoring, and oversight recur across the literature. Current studies leave open which governance arrangements work best, which monitoring thresholds are appropriate across settings, and whether the HSA lifecycle improves outcomes.

Every stage asks a different evidence question

HSA organizes AI assurance around six evidence moments. Purpose defines the permitted task, users, population, workflow, and boundary. Pre-deployment evidence asks whether the available performance, limitation, data, security, privacy, usability, and workflow evidence is fit for that intended context. Authorization records the accountable decision and conditions of use. Operation asks what is actually happening locally. Intervention defines what happens when evidence no longer supports normal use. Change and retirement determine when the original authorization must be reopened. [15-18]

AI assurance is a lifecycle responsibility



Source: The SozoRock Foundation analysis informed by lifecycle-oriented AI governance guidance [13-18]. The lifecycle is an organizing framework, not a universal regulatory checklist.

OPERATING IMPLICATION

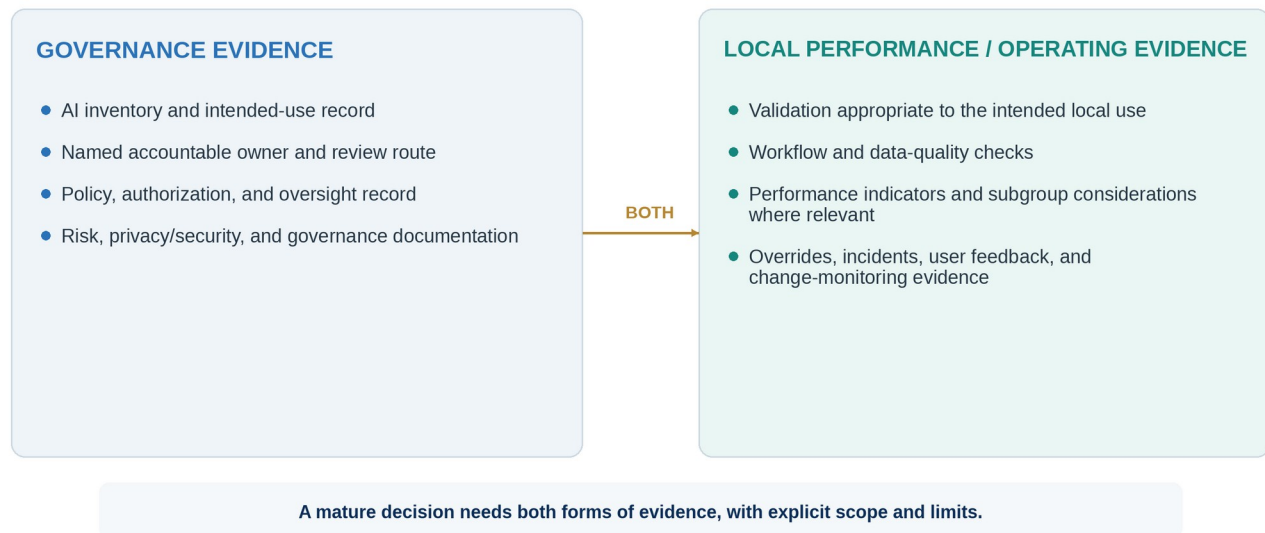
Authorization without monitoring creates a blind spot. Monitoring without a defined intervention and reauthorization path creates another.

Monitoring depth and cadence should reflect consequence, uncertainty, rate of change, available evidence, and applicable requirements. HSA therefore uses risk-based and event-driven review instead of one universal frequency or threshold.

Governance evidence and performance evidence answer different questions

A committee, policy, AI inventory, review workflow, and authorization record can demonstrate that governance exists. Local performance requires evidence from the relevant population and workflow. Evidence from a developer or another health system may also require local confirmation after changes in data, populations, interfaces, user behavior, or workflow design. [13-18]

Governance evidence cannot substitute for local performance evidence



Governance and transparency can strengthen oversight, but local clinical validity, operational performance, and change effects require separate evidence.

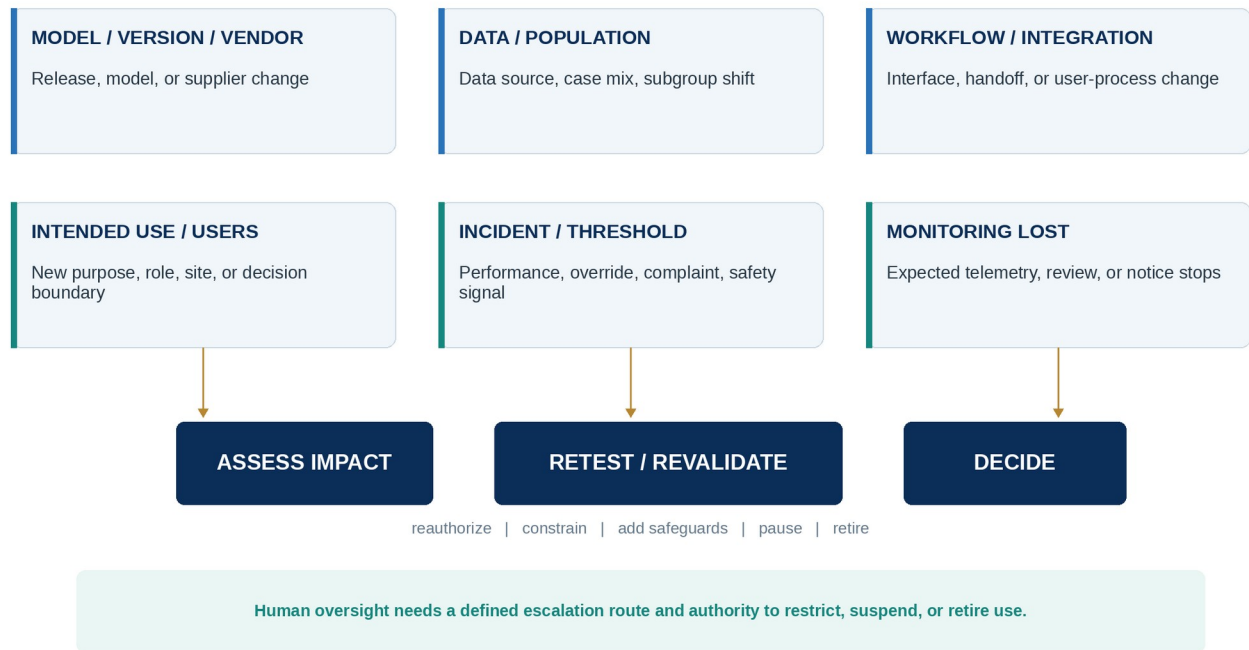
The same rule applies to vendor evidence. A model card, validation study, certification artifact, contract term, or supplier statement can be valuable. Its evidentiary value depends on scope, population, version, data, workflow, and the claim being made. HSA therefore treats external evidence as an input to local authorization, not as a substitute for it.

LOCAL CLINICAL EVIDENCE

HSA does not define universal clinical performance thresholds. Where local clinical validation is needed, the design, measures, sample, subgroup analysis, and decision thresholds require appropriate clinical and statistical methods.

AI assurance becomes fragile when authorization is treated as permanent. The HSA evidence architecture calls for monitoring of performance, data or context change, incidents, overrides, user feedback, and material vendor or model changes, together with explicit human oversight, incident response, reauthorization, and retirement paths. [15,16,13,14]

Material change should reopen the assurance question



The change triggers shown here are examples. Local thresholds should fit the intended use, risk, applicable law, and available evidence.

The important design principle is that monitoring must lead somewhere. A threshold breach, repeated override, material incident, loss of monitoring, or vendor change should create a defined decision path: investigate, constrain use, add safeguards, retest, pause, reauthorize, or retire. A dashboard that does not connect to authority and action is evidence collection, not assurance.

HUMAN OVERSIGHT

Human review is most useful when the reviewer has a defined role, escalation route, and authority to challenge, restrict, or stop use when the evidence no longer supports the authorized conditions.

Start with a small, disciplined operating set

Resource-constrained organizations may not begin with sophisticated model-monitoring platforms, large AI offices, or independent validation teams. The immediate objective is to preserve the functions that make accountable use possible: a controlled inventory, bounded purpose, evidence review, named owner, human oversight, incident visibility, change detection, and a stop-use or retirement path. WHO guidance and the broader HSA proportionality approach support adapting implementation to capacity while maintaining the decision and evidence functions that matter. [17,18,30,36]

A practical operating set for material AI-enabled capabilities

Operating element	What it asks the organization to show	Why it matters
1. Bound the use case	State the task or decision, intended users/population, workflow, owner and prohibited uses.	If scope is unclear, evaluation and accountability are unclear.
2. Review evidence before use	Match performance, limitation, data, security/privacy and workflow evidence to the intended context.	Generic or vendor evidence may not establish local fitness.
3. Record authorization	Name who approved use, residual risks, conditions, monitoring and escalation.	A go-live date is not an assurance conclusion.
4. Define human oversight	Specify where human review occurs, what can be overridden, and who can escalate or stop use.	Oversight without decision authority is weak evidence.
5. Monitor operation	Track a small set of meaningful indicators, incidents, overrides, complaints/feedback and change notices.	Monitoring should inform decisions as well as dashboards.
6. Reopen after material change	Assess model/vendor, data, workflow, intended-use and integration changes.	Original authorization may no longer match current conditions.
7. Preserve intervention paths	Define fallback, restriction, pause, investigation and remediation actions.	Evidence outside tolerance needs a response path.
8. Reauthorize or retire	Document the decision after material change, repeated failure, or loss of supporting evidence.	Continued use should remain a conscious accountable decision.

Source: The SozoRock Foundation analysis. Evidence and verification depth should be proportionate to risk and applicable obligations.

AI DECISION TEST

The central AI assurance question is whether evidence supporting continued use remains current, local enough for the claim being made, visible when it fails, and connected to an accountable decision.

The same lifecycle logic fits within the broader Health Systems Assurance agenda. Each material objective connects authority or risk, evidence, verification, monitoring, exceptions, remediation, and accountable decisions. AI therefore becomes one case within a common evidence architecture.

5

From compliance to evidence: the decision must be supportable

Compliance remains essential. It establishes duties, expectations, and control obligations. But the operating decision facing a health-system leader is narrower and more immediate: what material capability are we trusting, on what evidence, for how long, under what conditions, and who owns the decision when the evidence changes?

A supportable trust decision draws on policies, frameworks, certifications, vendor reports, network agreements, and AI reviews within their proper scope. None of these, by itself, establishes that the full local capability is operating as intended. HSA connects those mechanisms to the local operating evidence needed for the decision.

HSA PRINCIPLE

For every material digital capability, assurance should connect the reason it must be trusted to current evidence, proportional verification, visible exceptions, remediation, and an accountable decision.

The unit of analysis is the material capability - a digital capability whose failure or degradation could materially affect care, privacy, access, continuity, information integrity, or public trust. The architecture is intended to make the trust decision traceable across clinical, operational, technical, security, privacy, vendor, and governance boundaries without forcing those functions into a single standard.

HSA is presented here as an analytical and operating framework; reliability, validity, implementation burden, and outcome effects remain priorities for empirical research.

The HSA architecture begins with a bounded objective and ends with a decision. Between those points, the organization identifies why the objective matters, what evidence supports the claim, how that evidence is verified and refreshed, what counts as an exception, and what proves remediation or conscious risk acceptance. The point is traceability: a leader should be able to move from obligation or risk to operating evidence and then to action.

Assurance connects evidence to an accountable decision



Material change, stale evidence, incidents, or unresolved exceptions can reopen an earlier step.

The architecture is designed to make evidence ownership, refresh cadence, verification, exceptions, remediation, and decision rights explicit. Higher-risk capabilities may warrant independent verification.

The architecture complements authoritative sources. Law determines legal obligations. Standards and frameworks organize particular domains. Independent reports provide evidence within defined scopes. Clinical and professional requirements govern clinical decisions. HSA connects those inputs to a local operating claim and the accountable decision that follows.

DESIGN RULE

If the evidence cannot be traced to the claim, scope, owner, freshness, exception state, and decision, the organization has documentation but not yet a complete assurance record.

The claim should never be stronger than the evidence behind it

A recurring problem in assurance work is categorical language applied to evidence that is still partial. A policy may show intent. A design document may show a planned control. A log, ticket, completed review, exercise, or monitoring record may show operation. Repeated testing, exception visibility, and remediation evidence can support a stronger claim. The HSA Evidence Ladder is designed to make those differences explicit.

The claim should become stronger only as the evidence gets stronger



Assurance is scoped and time-bound; it is not an absolute state.

The six states - Unknown, Stated, Designed, Operating, Measured, and Assured - are introduced in this report. NIST SP 800-53A [7] and SP 800-137 [8] inform the general assessment and monitoring logic; they do not define this ladder.

The ladder measures the strength of evidence, not organizational prestige. A smaller organization can reach an operating or measured state using simple, controlled records and shared services. A large organization can remain at a stated or designed state if the relevant practice is well documented but not evidenced in operation.

Certification, spending, and organizational size do not determine the evidence level.

MEANING OF ASSURED

Assured is a scoped evidence state, not a guarantee of zero risk or permanent safety. It indicates that a defined claim is supported by sufficiently strong, current, tested evidence within a stated scope, and that failure or exception has a path to accountable action.

No single actor can create trustworthy digital operations alone

Assurance is distributed across organizations, networks, vendors, public programs, and funders. The practical objective is to make responsibilities explicit, reduce duplicated evidence work, and ensure that unresolved high-consequence exceptions reach the actor with authority to decide.

Actor responsibilities and decision tests

Actor	Immediate priority	Decision test
Federal government	Align research, technical assistance, interoperability, cybersecurity, and AI programs around evidence of operating performance rather than duplicative reporting.	Does the policy improve measurable operating evidence without creating another paperwork layer?
States / territories	Use Medicaid, public health, HIE, rural-hospital, procurement, and technical-assistance levers to support shared assurance capability where local capacity is thin.	Can smaller organizations meet the objective without reproducing enterprise infrastructure?
Local, Tribal & community systems	Plan for continuity, communication, referral, and access when material digital dependencies fail.	Is there a viable care pathway when a critical digital service is unavailable?
Health organizations	Identify material digital capabilities, assign owners, define exception states, and review unresolved high-consequence exceptions at executive or board level.	Can leadership show current evidence for the systems it depends on most?
Vendors & networks	Provide scoped evidence, material-change notices, incident obligations, subcontractor visibility, and continuity or exit information.	Does vendor evidence cover the dependency that matters in the local workflow?
Funders & research institutions	Finance validation, implementation, economic, and shared-service studies that answer defined questions with measurable public value.	Will the work answer a defined question with measurable public value?

Recommendations based on the Volume 1 findings. They are not universal legal duties and should be adapted to jurisdiction, organizational role, contractual responsibility, risk, and available capability.

A practical national assurance agenda can use existing levers - research, technical assistance, interoperability policy, cybersecurity programs, procurement, Medicaid and rural-health support - while keeping evidence ownership and accountability close to the organizations that deliver care.

POLICY TEST

Shared capability is useful when it lowers duplicated burden while preserving the same core question: can the responsible organization show why a material capability is trusted and what happens when that trust is no longer warranted?

Start with line of sight to the capabilities that matter most

Organizations can improve evidence discipline without waiting for a new regulation, enterprise platform, or certification scheme. A useful starting sequence is deliberately small: bound the priority set, assign ownership, create a controlled register, test one complete recovery path, and make AI and third-party lifecycle dependencies visible.

A practical assurance program can start with five actions

1 BOUND THE PRIORITY

Identify the 10-15 capabilities whose failure would matter most.

2 ASSIGN OWNERSHIP

Name an accountable owner and an evidence owner.

3 CREATE THE REGISTER

Link objective, evidence, exceptions, due dates, and closure.

4 TEST ONE RECOVERY

Exercise failure detection, workaround, restoration, and return to service.

5 MAP AI + THIRD PARTIES

Record critical dependencies, material changes, and incident routes.

DAY 90 OUTPUT: line of sight into material capabilities, evidence, exceptions, recovery, and decision rights - not a certification claim.

The 10-15 capability starting set and 90-day sequence are a practical starting point; organizations should adapt them to applicable requirements, clinical context, and risk.

At the end of the first 90 days, the organization should not claim to be "assured." The more useful result is a working line of sight: leaders know which capabilities matter most, who owns the decision and evidence, where the evidence sits, which exceptions are open, whether a recovery pathway has been exercised, and which AI or external dependencies require lifecycle review.

EXECUTIVE REVIEW QUESTION

For the systems we depend on most, can we show current evidence, unresolved exceptions, the next review point, and who has authority to accept, remediate, restrict, or stop?

The longer-term opportunity is to lower execution burden while preserving accountability. That means institutionalizing evidence refresh and exception review inside health organizations while building shared capabilities where duplication is costly: vendor evidence review, monitoring support, resilience exercises, AI evaluation assistance, technical expertise, and independent testing where risk warrants.

Scale assurance through common evidence, shared capacity, and tested implementation



These time horizons are planning ranges. Actual timing should reflect organizational risk, capability, dependencies, and context. Four guardrails should remain in place as the agenda scales: keep HSA risk-based instead of turning it into a universal checklist; treat the Evidence Ladder as an evidence model rather than a certification or prestige score; keep external and vendor evidence distinct from local operating proof; and preserve accountability when implementation is proportional.

NEXT RESEARCH STEP

The next step is empirical: test whether different reviewers can apply HSA consistently, whether its evidence states distinguish meaningful operating conditions, what implementation costs, which shared services improve feasibility, and whether better assurance improves remediation, resilience, or trust.

What should be tested next

Volume 1 documents the operating problem and introduces an architecture for organizing assurance decisions. The next step is to test whether HSA can be applied consistently, whether its evidence states correspond to meaningful differences in operating proof, what implementation burden it creates, and whether it improves decisions or outcomes.

Eight research questions would test reliability, performance, cost, and trust

Priority	Question to test	Study design
01 Reliability	Can independent assessors apply the HSA evidence architecture consistently?	Multi-site double-rating study
02 Validity	Do stronger evidence states correspond with independently assessed control effectiveness or resilience outcomes?	Prespecified comparison with external operating evidence
03 Feasible implementation	Can prioritized or shared-service approaches improve evidence completeness without excessive burden?	Pragmatic multi-site implementation study
04 AI lifecycle	Which evidence practices best detect degradation, unsafe use, or material change?	Prospective multi-site implementation study
05 Third-party assurance	Which vendor-evidence practices improve dependency decisions, detection, and remediation?	Comparative implementation study
06 Care disruption	Which digital-control failures measurably disrupt care, and what shortens recovery?	Standardized incident registry + multi-site study
07 Economics + burden	What does digital assurance cost, and where is burden concentrated?	Activity-based costing
08 Patient + community trust	Which transparency and accountability practices matter most to patients and communities?	Community-engaged research

The first priority is reliability and feasibility across resource-diverse organizations. Subsequent studies should examine criterion validity, AI lifecycle performance, third-party dependencies, care disruption, implementation cost, and patient and community trust.

These questions require different study designs, measures, and settings. A coherent research program can share definitions and infrastructure while keeping each claim tied to evidence that can actually answer it.

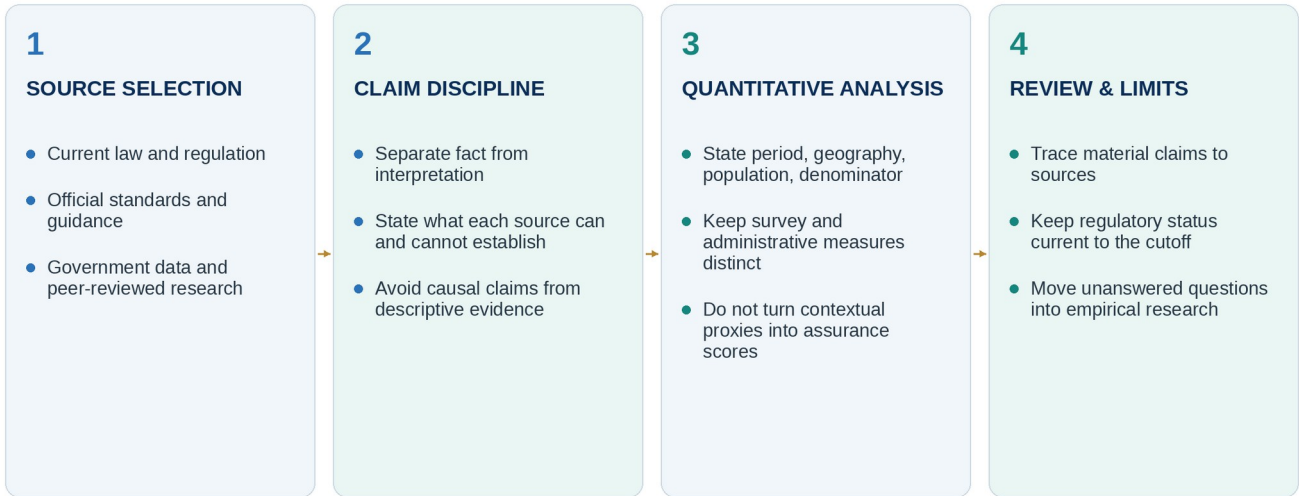
RESEARCH STANDARD

Each study should name the decision it aims to improve, the evidence it will collect, the population or setting represented, and the claims the design cannot support.

How the evidence was assembled

Volume 1 is an independent evidence synthesis and policy analysis with selected secondary quantitative analysis. The evidence base prioritizes authoritative public records, current law and regulation, official standards and technical guidance, government datasets, peer-reviewed evidence syntheses, and empirical studies. Consultancy and vendor material is used only for context when stronger sources are unavailable.

Four controls shape the analysis



This report does not include original patient-level or organizational field research.

Evidence cutoff: August 12, 2026. The source register identifies the public record supporting the analysis.

Material claims are traceable to their sources and separated into direct descriptive evidence, interpretation, and the HSA framework introduced in this report. Numerical claims identify the relevant period, geography, population or denominator, and source construction. Causal claims are reserved for evidence with an appropriate study design.

Quantitative analysis is limited to questions the underlying data can answer. Survey estimates, administrative datasets, public-use files, place-based indicators, and published studies are treated according to their design and scope. Structural variables such as financial capacity, workforce, rurality, broadband availability, and social vulnerability describe implementation context; they are not converted into organizational assurance scores.

STUDY SCOPE

Volume 1 is based on public and published evidence plus selected secondary quantitative analysis. Interviews, surveys, Delphi panels, and organizational field validation are reserved for subsequent empirical studies.

Public evidence can reveal the context of assurance. It cannot substitute for operating proof.

The central limitation is that public evidence cannot directly observe whether a specific organization has implemented, tested, monitored, and remediated the controls and workflows on which its trust decisions depend. The report therefore states those limits explicitly and avoids treating missing data as evidence of missing capability.

The boundaries that govern interpretation

Limitation	Why it matters	Implication for interpretation
Empirical scope	Most quantitative context is U.S.-centered. International standards and studies broaden context but do not create global representativeness.	The findings are reported as U.S.-centered; comparative work elsewhere requires locally designed research.
Public-data coverage	Control operation, governance quality, exception closure, test evidence, and many local AI/vendor decisions are not publicly observable.	Public data describe context and patterns but do not establish organization-specific operating assurance.
Descriptive / observational evidence	Many analyses describe associations, reported participation, or observed disruption rather than causal effects.	Associational evidence is not treated as causal without a stronger research design.
Survey and reporting construction	ASTP/ONC files are survey-based; OCR breach data are thresholded, reported, amendable, and lack a complete denominator.	Survey construction, reporting rules, and access dates are disclosed; nonresponse is not treated as absence.
Time and definition mismatch	Datasets use different years, reporting periods, definitions, and classification systems.	Measures are reported with explicit vintages and definitions; non-comparable measures are not merged.
Proxy-variable misuse	Financial, workforce, broadband, and community-vulnerability measures describe context, not control effectiveness.	Structural indicators remain contextual and are not converted into an assurance score.
HSA research status	The Evidence Architecture, Evidence Ladder, thresholds, cadences, and implementation sequence require reliability, validity, burden, and outcome testing.	These constructs are research propositions pending empirical testing; they are not a certification, standard, or nationally representative measure.

These limitations govern interpretation of the findings and should be read alongside the source notes.

The empirical base is predominantly U.S.-centered. International standards, global guidance, and international peer-reviewed research provide comparative context without making U.S. hospital findings globally representative. Comparative work in Canada and other settings should be designed around local law, institutions, data, and implementation conditions.

INTERPRETATION NOTE

Public variables should be treated as context. Missing public data cannot establish absence of a capability; policies, certifications, attestations, and contextual proxies cannot establish local operating effectiveness.

Notes and sources

References correspond to the source numbers used throughout the report. Government, standards-body, professional, and research sources are identified at the level necessary for retrieval and verification. Proprietary standard text is not reproduced. Evidence cutoff: August 12, 2026.

- [1] ASTP/ONC. Electronic Health Information Exchange by Hospitals. Health IT Quick Stat #66. Updated February 2026.
- [2] ASTP/ONC. Non-Federal Acute Care Hospitals' Awareness of and Plans to Participate in TEFCA. Health IT Quick Stat #64. Updated February 2026.
- [3] ASTP/ONC. HHS Expands Secure Access to Health Records Through the TEFCA Network, Announces Milestone of One Billion Health Records Exchanged. June 26, 2026.
- [4] U.S. Department of Health and Human Services. Healthcare and Public Health Cybersecurity Performance Goals.
- [5] U.S. Department of Health and Human Services, Office for Civil Rights. HIPAA Security Rule Notice of Proposed Rulemaking to Strengthen Cybersecurity for Electronic Protected Health Information. At the evidence cutoff, the current Security Rule remained in effect during rulemaking.
- [6] National Institute of Standards and Technology. The NIST Cybersecurity Framework (CSF) 2.0. NIST CSWP 29. 2024. doi:10.6028/NIST.CSWP.29.
- [7] National Institute of Standards and Technology. SP 800-53A Rev. 5: Assessing Security and Privacy Controls in Information Systems and Organizations.
- [8] National Institute of Standards and Technology. SP 800-137: Information Security Continuous Monitoring for Federal Information Systems and Organizations.
- [9] AICPA & CIMA. SOC 2 Reporting on an Examination of Controls at a Service Organization Relevant to Security, Availability, Processing Integrity, Confidentiality, or Privacy.
- [10] International Organization for Standardization. ISO 27799:2025. Health informatics - Information security controls in health based on ISO/IEC 27002.
- [11] International Organization for Standardization. ISO 7101:2023. Healthcare organization management - Management systems for quality in healthcare organizations - Requirements.
- [12] ASTP/ONC. Trusted Exchange Framework and Common Agreement (TEFCA). Updated June 9, 2026.
- [13] ASTP/ONC. Health Data, Technology, and Interoperability: Certification Program Updates, Algorithm Transparency, and Information Sharing (HTI-1) Final Rule.
- [14] ASTP/ONC. Decision Support Interventions, Section 170.315(b)(11), Certification Companion Guide. Updated May 5, 2026.
- [15] National Institute of Standards and Technology. Artificial Intelligence Risk Management Framework (AI RMF) 1.0. NIST states version 1.0 is being revised.
- [16] International Organization for Standardization. ISO/IEC 42001:2023. Information technology - Artificial intelligence - Management system.
- [17] World Health Organization. Ethics and governance of artificial intelligence for health. 2021.
- [18] World Health Organization. Regulatory considerations on artificial intelligence for health. 2023.
- [19] National Institute of Standards and Technology. SP 800-161 Rev. 1: Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations.
- [20] Centers for Medicare & Medicaid Services. Cost Reports / Healthcare Cost Report Information System (HCRIS). Updated July 2026.
- [21] Health Resources and Services Administration. Area Health Resources Files (AHRF).
- [22] Federal Communications Commission. How to Use the FCC's National Broadband Map.
- [23] U.S. Department of Health and Human Services, Office for Civil Rights. Breach Portal: Breaches of Unsecured Protected Health Information Affecting 500 or More Individuals.

- [24] Dameff C, Tully J, Chan TC, et al. Ransomware Attack Associated With Disruptions at Adjacent Emergency Departments in the US. *JAMA Network Open*. 2023;6(5):e2312270. doi:10.1001/jamanetworkopen.2023.12270.
- [25] Neprash HT, McGlave CC, Rydberg K, Henning-Smith C. What happens to rural hospitals during a ransomware attack? Evidence from Medicare data. *Journal of Rural Health*. 2024;40(4):728-737. doi:10.1111/jrh.12834.
- [26] Tully JL, Rao S, Straw I, et al. Patient Care Technology Disruptions Associated With the CrowdStrike Outage. *JAMA Network Open*. 2025;8:e2530226.
- [27] Alami H, Pozelli Sabio R, Perez EJ, et al. Artificial Intelligence Governance in Health Systems: Systematic Review of Frameworks and Integrative Model Proposal. *Journal of Medical Internet Research*. 2026;28:e87448. doi:10.2196/87448.
- [28] Wang A, Freeman S, Magrabi F. Governance for safe and responsible AI in healthcare organisations: a scoping review of frameworks. *npj Digital Medicine*. 2026;9:516. doi:10.1038/s41746-026-02679-2.
- [29] Preti LM, Ardito V, Compagni A, Petracca F, Cappellaro G. Implementation of Machine Learning Applications in Health Care Organizations: Systematic Review of Empirical Studies. *Journal of Medical Internet Research*. 2024;26:e55897. doi:10.2196/55897.
- [30] World Health Organization. Global strategy on digital health 2020-2027.
- [31] Government of Ontario. Personal Health Information Protection Act, 2004, S.O. 2004, c. 3, Sched. A. Current consolidated law at the evidence cutoff.
- [32] National Institute of Standards and Technology. SP 1300: NIST Cybersecurity Framework 2.0: Small Business Quick-Start Guide.
- [33] ASTP/ONC. U.S. Hospital Participation in Health Information Networks, 2022-2025. Public-use dataset. Updated May 2026.
- [34] Pham TT, Loo TM, Malhotra A, et al. Ransomware Cyberattack Associated With Cardiac Arrest Incidence and Outcomes at Untargeted, Adjacent Hospitals. *Critical Care Explorations*. 2024;6:e1079.
- [35] Jiang JX, Ross JS, Bai G, et al. Trends in Ransomware Attacks on US Hospitals, Clinics, and Other Health Care Delivery Organizations, 2016-2021. *JAMA Health Forum*. 2022.
- [36] World Health Organization. World Health Assembly endorses extension of the Global Strategy on Digital Health to 2027. May 23, 2025.
- [37] ASTP/ONC. Percent of Hospitals, By Type, that Possess Certified Health IT. Health IT Quick Stat #52. Updated June 2026.
- [38] ASTP/ONC. Methods Used by Hospitals to Engage in Interoperable Exchange. Health IT Quick Stat #70. Updated February 2026.
- [39] ASTP/ONC. Health Data, Technology, and Interoperability: Patient Engagement, Information Sharing, and Public Health Interoperability (HTI-2) Final Rule. Updated April 29, 2026.
- [40] National Institute of Standards and Technology. SP 1308: NIST Cybersecurity Framework 2.0: Cybersecurity, Enterprise Risk Management, and Workforce Management Quick-Start Guide. March 2026. doi:10.6028/NIST.SP.1308.

Acknowledgments and disclosures

Dr. Oluwabiyi Adeyemo authored Volume 1. The SozoRock Foundation Inc. acknowledges the public agencies, standards bodies, researchers, and institutions whose data, technical guidance, and published research informed the analysis. Citation recognizes those contributions to the public evidence base; it does not imply participation in, review of, or endorsement of the Health Systems Assurance framework or the conclusions in this report.

No external research funding was received for Volume 1. The author and publisher retained responsibility for the scope, analysis, interpretation, recommendations, and publication decisions. Any errors remain the responsibility of the author and publisher.

The report relies on original synthesis and properly attributed public or published evidence. Proprietary standards, paid instruments, and distinctive third-party language are not reproduced.

About the author

Dr. Oluwabiyi Adeyemo is Director of Strategic Initiatives at The SozoRock Foundation Inc. and author of the Health Systems Assurance Series. He leads research and strategy on health-system evidence, digital infrastructure, AI governance, data governance, workforce development, and implementation capacity. He developed the Health Systems Assurance framework to connect obligations and risk objectives with operating evidence, monitoring, exceptions, remediation, and accountable decisions. His broader work at the Foundation includes health equity, digital access, and the institutional capacity needed to move evidence into implementation.

About the publisher

The SozoRock Foundation Inc. is a New York nonprofit organization focused on health systems equity, research, literacy, and workforce development. Through research, programs, and partnerships, the Foundation works to translate evidence into practical systems that strengthen access, governance, and implementation capacity. Health Systems Assurance is its research series on evidence, accountability, and operating discipline for digital and AI-enabled health infrastructure.

health.sozorockfoundation.org | contact@sozorockfoundation.org

About the series

Health Systems Assurance is a SozoRock Foundation research series on the evidence, governance, accountability, and operating discipline needed for trustworthy digital and AI-enabled health infrastructure. Volume 1 establishes the public evidence base and a practical architecture for connecting obligations and risk objectives to current evidence, visible exceptions, remediation, and accountable decisions.

FIRST EDITION | AUGUST 2026 | ISBN 979-8-9936477-3-9

THE SOZOROCK FOUNDATION INC.

Trust in digital health should be supported by evidence.

Health systems now rely on networks of electronic health records, cloud services, identity platforms, vendors, exchange infrastructure, and AI-enabled tools. The central question is no longer whether organizations have policies and frameworks. It is whether leaders can show, with current evidence, that material digital capabilities are operating as intended and that failures, changes, and exceptions lead to accountable decisions.

Volume 1 distinguishes adoption from assurance, maps the roles and limits of existing mechanisms, examines how place and capacity shape implementation, and introduces an evidence architecture for digital operations, AI lifecycle oversight, third-party dependencies, remediation, and continuity.

- **OPERATING EVIDENCE**

Connect obligations to evidence that can be reviewed.

- **LIFECYCLE ASSURANCE**

Revisit trust when systems, data, vendors, or conditions change.

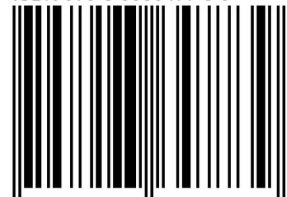
- **ACCOUNTABLE DECISIONS**

Make exceptions, remediation, and stop-use authority visible.

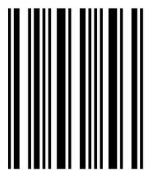
Dr. Oluwabiyi Adeyemo

The SozoRock Foundation Inc.
health.sozorockfoundation.org
contact@sozorockfoundation.org

ISBN 979-8-9936477-3-9



9 798993 647739



90000